Statement of Applicability (SoA): Extract of 10 Sampled Controls

Note: This is a portfolio project. The company, interviews, and findings are fictional and simulated. The compliance score is illustrative, not an ISO metric.

Candidate / Author: Junior GRC Analyst (Portfolio Assessment)

Target Organization Scope: VortexPe Cloud Services India Pvt. Ltd. (AWS Cloud Infrastructure, EKS Clusters, Financial APIs, and PII Repositories)

Evaluated Frameworks: ISO/IEC 27001:2022 (Annex A), NIST CSF 2.0, and Digital Personal Data Protection (DPDP) Act 2023

Assessment Date: October 2026

1. Executive Summary & Assessment Context

As part of my practical GRC portfolio training, I conducted a hands-on gap assessment for VortexPe Cloud Services—a cloud-native fintech platform hosted on AWS. My objective was to evaluate the company's security posture against **ISO/IEC 27001:2022 (Annex A)**, **NIST CSF 2.0**, and the **Indian DPDP Act 2023**, transitioning theoretical compliance requirements into an actionable risk assessment.
Across the 10 evaluated control scenarios:

- **Overall Compliance Score: 50.0%** across 9 applicable controls.
- **Control Breakdown:** 2 controls are Fully Implemented, 5 controls are Partially Implemented, and 2 controls are Not Implemented.
- **Inherited Controls:** 1 control (ISO A.7.1 Physical Security) is inherited from AWS for data-centre protection under the Shared Responsibility Model and is not scored.

While the platform demonstrates strong baseline maturity in operational logging (A.8.15) and vulnerability management (A.8.8), I identified **two Critical-risk gaps** that require immediate remediation:

1. **Unmasked Customer PII in Staging (A.8.12 / DPDP Act):** Non-production environments process real customer PII without data masking or automated Data Leakage Prevention (DLP).
2. **Unverified Disaster Recovery Failover (A.5.29 / NIST ID.IM-02):** Multi-region failover testing has not been executed in the past 12 months, creating SLA availability risks.

2. Compliance Metrics & Risk Profile

Table 1: Compliance Status Summary

Metric	Count	Percentage of Controls Evaluated	Notes & Candidate Observations
Total Controls Evaluated	**10**	100%	Full scope across Cloud, IAM, Data Privacy, BCP, and DevSecOps.
Applicable Controls (SoA)	**9**	90.0%	Controls within direct operational and engineering boundary.
Inherited Controls (SoA)	**1**	10.0%	Inherited via AWS SOC 2 Type II / ISO 27001 certifications (A.7.1 Physical Security).
Fully Implemented	**2**	20.0%	Log streams to SIEM with WORM Object Lock & automated CVE scanning.
Partially Implemented	**5**	50.0%	IaC baselines, CLI MFA enforcement, K8s image signing, KMS key rotation, and SAST.
Not Implemented	**2**	20.0%	Staging PII data masking/DLP & Multi-region DR failover testing.

Overall Compliance Score	**50.0%**	—	Weighted calculation: (Fully Implemented * 1.0) + (Partially Implemented * 0.5) / Total Applicable Controls (illustrative).

Table 2: Inherent Risk Level Breakdown

Risk Level	Count	Target Timeline	Primary Focus Areas
CRITICAL	**2**	**30 Days**	Non-production PII Exposure (A.8.12) & Unverified DR Failover (A.5.29).
HIGH	**4**	**30 to 60 Days**	Manual AWS console setups (A.5.23), CLI MFA gaps (A.5.15), Unsigned K8s images (A.8.9), Manual SAST (A.8.28).
MEDIUM	**1**	**60 Days**	Default KMS service keys without Customer Managed Keys (CMK) (A.8.24).
LOW	**3**	**90 Days / Maintain**	SIEM logging (A.8.15), Container CVE scanning (A.8.8), Physical Security (A.7.1 - Inherited).

3. Detailed Audit Findings & Analysis

Finding 1: Unmasked Customer PII in Non-Production Environments (CRITICAL)

- **Mapping:** ISO 27001:2022 A.8.12 (primary), A.8.11, A.8.33 | NIST CSF PR.DS-01 | DPDP Act 2023 (Data Fiduciary security safeguards, Sec 8)
- **Condition:** Production database snapshots containing customer PII (PAN, phone numbers, transaction history) are cloned into staging without data masking or tokenization, and no automated DLP monitoring is in place.
- **Criteria:** A.8.11 requires data masking where appropriate; A.8.33 requires test information to be selected, protected, and managed; A.8.12 requires data leakage prevention measures.
- **Cause (likely, to be confirmed with management):** The snapshot-restore pipeline has no masking step, and staging is treated as lower risk.
- **Effect:** A staging or developer-device compromise would expose real customer data, creating regulatory, legal, and reputational exposure under the DPDP Act.
- **Recommendation:** Add masking or tokenization to the snapshot-restore pipeline, restrict staging access, and use AWS Macie to scan S3 exports and backups for PII.

Finding 2: Disaster Recovery Failover Not Tested (CRITICAL)

- **Mapping:** ISO 27001:2022 A.5.29 (also A.5.30) | NIST CSF ID.IM-02
- **Condition:** No multi-region failover test or simulation has been performed in the past 12 months, and RTO/RPO are not documented in customer contracts.
- **Criteria:** A.5.29 requires information security to be maintained during disruption; A.5.30 requires ICT readiness to be planned, implemented, maintained, and tested against business continuity objectives.
- **Cause (likely, to be confirmed with management):** DR capability exists in design, but no recurring test schedule has been set.
- **Effect:** A regional outage could extend downtime and breach the 99.9% uptime SLA during live transaction processing.
- **Recommendation:** Define RTO/RPO through a business impact analysis (proposed starting point: 4 hours / 15 minutes), document the DR runbook, and run a multi-region failover drill.

Finding 3: No MFA Enforcement on AWS CLI/API Access (HIGH)

- **Mapping:** ISO 27001:2022 A.8.5, A.5.15 | NIST CSF PR.AA-03

- **Condition:** AWS console logins enforce MFA, but CLI/API access uses long-lived access keys with no MFA session requirement.
- **Criteria:** A.8.5 requires secure authentication appropriate to access restrictions and risk; A.5.15 requires access to be controlled according to business and security **requirements.**
- **Cause (likely, to be confirmed with management):** Long-lived access keys were issued for convenience and never moved to short-lived sessions.
- **Effect:** A leaked or stolen key could give administrative control of cloud resources without an authentication challenge.
- **Recommendation:** Require MFA-backed short-lived session credentials for privileged CLI/API actions, and retire long-lived admin keys.

Finding 4: Container Image Signatures Not Enforced in Production EKS (HIGH)

- **Mapping:** ISO 27001:2022 A.8.9 | NIST CSF PR.PS-05
- **Condition**: Per the simulated DevOps Lead interview, images are signed in some build pipelines, but the EKS clusters have no admission control that rejects unsigned or unverified images.
- **Criteria:** Secure configuration of the deployment environment (A.8.9) should prevent installation and execution of unauthorized software (PR.PS-05)**.**
- **Cause (likely, to be confirmed with management):** Signing was adopted per pipeline without a cluster-level enforcement policy.
- **Effect:** Unverified or tampered images could run in production namespaces, creating a software supply chain risk.
- **Recommendation:** Enforce signature verification with Kyverno or Cosign admission policies, starting in audit mode and then moving to block mode.

4. 30-60-90 Day Risk Remediation Strategy

Phase 1: Immediate Critical Risk Mitigation (0 - 30 Days)

- Deploy dynamic schema-level PII data masking on database staging snapshots
- Enforce mandatory TOTP/Hardware MFA on AWS CLI/API session credentials
- Conduct multi-region DB failover simulation and publish documented RTO/RPO targets

Phase 2: Architectural Guardrails & DevSecOps (31 - 60 Days)

- Convert manual AWS Console setups into Terraform IaC templates with GuardDuty
- Enforce Cosign/Kyverno image signature verification on EKS clusters
- Migrate AWS KMS keys to Customer Managed Keys (CMK) with 90-day rotation
- Embed SonarQube/Semgrep SAST scans into GitHub Actions build pipelines

Phase 3: Continuous Governance & Verification (61 - 90 Days)

- Set up automated compliance tracking via AWS Security Hub
- Conduct annual third-party review of AWS SOC 2 Type II audit reports
- Execute quarterly log retention and SIEM WORM Object Lock verification